Domain 2: Asset Security

- **Identify and Classification of Assets**
  - **Classification**
    - The First step in asset security is identifying and classifying information & Assets
    - Ensure information is marked in such a way that only those with an appropriate level of clearance can have access to the information.
    - The **Purpose of Asset classification is to ensure that assets are properly identified** and protected throughout their lifecycle.
      - Asset classification informs handling instructions, control decisions, and audit scope & regulatory compliance activities.
      - Information assets are generally classified by content.
      - Infrastructure and physical assets are generally classified by the criticality of the services they provide.
    - **The individual who owns the data should decide on the data classification i.e Data Owner should review the data classification annually.**
    - Two factors to be considered while the classification of the data
      - Critical of data (Availability)
        - Categorize the data/deals with impact.
        - Define the time-sensitivity of data.
      - Sensitivity of data (Disclosure)
        - The amount of damage that would be done should the information be disclosed
    - Based on the asset value towards the organization, categorize them in ways Top secret, secret, Confidential.
    - **Data classification may assist an organization in reducing costs for protecting data.**

  - **Data classification** is all about analyzing the data that the organization has, in whatever form, determining its importance and value, and then assigning it to a category or classification level.

  - Classification deals with Access
  - Categorization deals with Impact
  - **Sensitivity** - Classify the data / deals with access / confidentiality
    - **Sensitivity** describes the amount of damage that would be done should the information be disclosed
  - **Criticality** - categorize the data/deals with the impact
    - **Criticality** describes the time-sensitivity of the date, this is usually driven by an understanding of how much revenue a specific asset generates, and without that asset, there will be lost revenue.

- **Data classification considerations: please remember the below for exam point of view**
  - **The value of the data to the organization, which can change over time**
  - **The level of damage that could be caused if the data were compromised, corrupted, or damaged**
  - **Legal, regulatory, or other responsibilities to protect the data**
  - **Industry and the purpose/mission which the organization operates**

- **Data classification policy - factors to be considered**
  - Who will have access to the data
    - Define the roles of people who can access the data
  - How the data is secured
    - Determine whether the data is generally available or, by default, off-limits
  - How long the data is to be retained - defined by the Data owner
    - Data owners need to know the regulatory requirements for their data, and if requirements do not exist, they should base the retention period on the needs of the business.
  - What method(s) should be used to dispose of the data
  - Whether the data needs to be encrypted - ex PCI/DSS regulatory data needs to be encrypted
    - Data owners will have to decide whether their data needs to be encrypted
  - The appropriate use of the data
    - This aspect of the policy defines whether data is for use within the company, is restricted for use by only selected roles, or can be made public to anyone outside the organization.

- **Purpose of Asset Classification**
  - Inventory management plays a very important role in an asset classification system.
  - Maintains the inventory of the assets & their associated values.
  - Ensure that information assets receive an appropriate level of protection.
  - Provide security classifications that will indicate the need and priorities for security protection.
  - Minimize the risk of unauthorized information alteration
  - Avoid unauthorized disclosure
  - Maintain competitive edge

- Protect legal tactics.
- Comply with privacy laws, regulations & industry standards.

- **Asset Classification Process**
  1. Identify the asset
  2. Determine who is accountable/responsible for the integrity of the asset
  3. Establish ownership of the asset
  4. Place a value on the asset
  5. Prepare a schema (structure) for classifying your assets
  6. Implement the classification schema

- **Type of Classification (EXAM QUESTION)**
  - **Military**
    - Top Secret ,Secret ,Confidential ,Unclassified
  - **Commercial (Organization)**
    - Private, Company Restricted, Company Confidential, Public

- **Type of Classification Level**
  - Top Secret
    - Data that is defined as being very sensitive, possibly related to privacy, bank accounts, or credit card information.
  - Company Restricted
    - Data that is restricted to properly authorized employees.
  - Company Confidential:
    - Data that can be viewed by many employees but is not for general use.
  - Public
    - Data that can be viewed or used by employees or the general public.

- **These are the steps involved to do this properly**:
  1. **Identify and locate assets, including information.**
     - Valuable asset needs to be identified to protect them accordingly.
     - E.g. Information assets, Software assets, Physical assets.
  2. **Classify based on value.**
     - Process is to determine ownership to establish accountability
     - The owners are always in the best position to understand the value of what they own; therefore, it is up to the owners to classify assets.
     - The process of understanding the value of an asset is very appropriately called asset valuation.
  3. **Protect based on classification.**
     - Protect the assets based on their classification levels
     - Establish the minimum Security baseline for each classification level that exits.

     Categorization
       - The process of determining the impact of the loss of confidentiality, integrity, availability of the information to an organization.
       - Categorization deals with Impact Criticality - categorize the data/deals with the impact
       - It's a part of companies overall risk management strategy

     (One more Example)
     - **Asset inventory**
     - **Determine and assign ownership**
     - **Classify based on value**
     - **Protect and handle based on classification**
     - **Assess and review**

- **Classification Benefits**
  - Awareness among employees and customers of the organization's commitment to protecting information.
  - Identification of critical information.
  - Identification of vulnerability to modification.
  - Identification of critical information: identifies information that the organization considers critical to business success.
  - Identification of sensitivity to modification: classification helps identify data that must only be modified in specifically authorized ways.
- **Issue Related to Classification**
  - Human error.
  - Proper classification is dependent on the ability and knowledge of the classifier.
  - Requires awareness of regulations and customer and business expectations.

- Requires consistent classification method—often the decisions can be somewhat arbitrary.
- Needs clear labeling of all classified items.
- Must include manner for declassifying and destroying material in the classification process.

- **Based on Value**
  - Assets and resources, imply value to an organization and, therefore, must be protected based on the value that it represents to the organization.
  - Value can be expressed in terms of quantitative Qualitative asset valuation implies that value is expressed in terms of numbers
  - Actual value of assets becomes very important in understanding how to protect those assets because the value will always dictate the level of security required.

- **Protection of the value of asset & information**
  - Identifying and classifying assets and information will allow organizations to determine and achieve the protection requirements for the information

- **Classification and Categorization are used to help standardize the protection baselines for information systems and the level of suitability and trust an employee may need to access information.**

- **Common classes of Sensitive Data/information include:**
  - **Personally identifiable information (PII)** uniquely identifies individuals.
  - **Protected health information (PHI)** includes individual health records.
  - **Proprietary information** which contains trade secrets.

- **Information and Asset Ownership**
  - Compliance requirements will treat personal information as data that requires protection at every step of its lifecycle, from collection to processing, to storage, to archiving, and to destruction.
  - Protection of data requires the clear distinction of roles, accountabilities, and responsibilities to be identified and defined

- **Data Subject**
  - Individual who is the subject of personal data

- **Data Owner**
  - Accountable for determining the value of the data.
  - Data owners also are accountable for defining policies for access of the data and clearly defining and communicating the responsibilities for such protection to other entities including stewards, Custodians, and processors.

- **Data Controller**
  - An entity that collects or creates PII. The data owner/controller is legally responsible
  - for the protection of the PII in their control and liable for any unauthorized release of PII.
  - Ostensibly, the owner/controller is an organization; the legal entity that legitimately owns the data.

- **Data Steward**
  - Data stewards are commonly responsible for data content, context, and associated business rules within the organization.
  - Deal with Business data
  - Data protection officer is data steward /
  - Data steward is concerned with the meaning of data and the correct usage of data.
- **Data Processor**
  - Any entity, working on behalf or at the behest of the data controller, that processes PII. Under most PII-related laws, "processing" can include absolutely anything that can be done with data: creating, storing, sending, computing, compiling, copying, destroying, and so forth.
  - While the data processor does have to comply with applicable PII law, it is the data owner/controller that remains legally liable for any unauthorized disclosure of PII even if the processor is proven to be negligent/malicious.

- **Data Custodian**
  - The person/role within the organization who usually manages the data on a day-to-day basis on
  - behalf of the data owner/controller.
  - This is often a database manager or administrator; other roles that might be considered data custodians could be system administrators or anyone with privileged access to the system or data set.

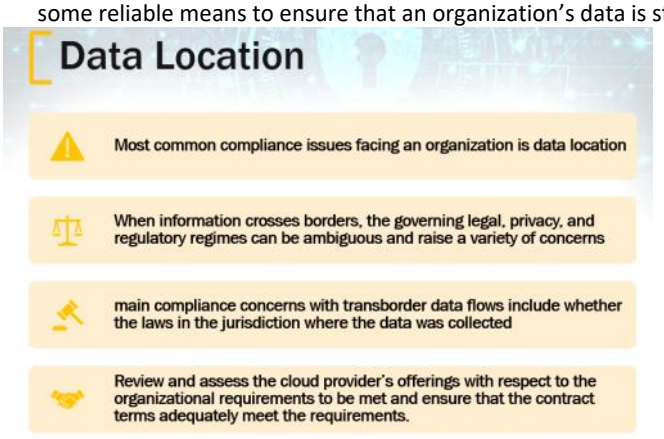
- **Difference Between Data Owner/Controller and Data Custodian/Processor**
  - Data owner and the Data custodian accountable for the protection of what they own based on the value of that asset to the organization.
  - The controller will act as the owner and, therefore, becomes accountable for the protection based on expectations related to legislation and

regulations.

- **Protect Privacy**
  - Privacy
    - Right of the individual to control their Personal Data
    - Data collection should be restricted.
    - Data owners have a responsibility to respect and enforce privacy principles.
    - Data processes should ensure enforcement of privacy and data integrity.
    - Data remanence techniques should be used to permanently delete data.
- **Data Location**

  The main compliance concerns with transborder data flows include whether the laws in the jurisdiction where the data was collected permit the flow, whether those laws continue to apply to the data post transfer, and whether the laws at the destination present 18 additional risks or benefits

  Technical, physical and administrative safeguards, such as access controls, often apply. For example, European data protection laws may impose additional obligations on the handling and processing of data transferred to the U.S. These concerns can be alleviated if the cloud provider has some reliable means to ensure that an organization's data is stored and processed only within specific jurisdictions.



- **Data sovereignty is the concept that information which has been converted and stored in binary digital form is subject to the laws of the country in which it is located.**
  - **Many of the current concerns that surround data sovereignty relate to enforcing privacy regulations and preventing data that is stored in a foreign country from being subpoenaed by the host country's government.**
  - **Data sovereignty can have an impact on privacy, confidentiality, and accessibility of your data.**
- **OECD Privacy Principles = Must know each feature**
  - **Collection Limitation Principle**
    - There should be limits to the collection of personal data, and any such data should be obtained by lawful and fair means and, where appropriate, with the knowledge or consent of the data subject.
  - **Data Quality Principle**
    - Personal data should be relevant to the purposes for which it is to be used, and, to the extent necessary for those purposes, should be accurate, complete, and kept up to date
  - **Purpose Specification Principle**
    - The purpose for which personal data is collected should be specified during the time of data collection.
  - **Use Limitation Principle**
    - Personal data should not be disclosed, made available, or otherwise used for purposes other than those specified except with the consent of the data subject or by the authority of law.
  - **Security Safeguard Principle**
    - Personal data should be protected by reasonable security safeguards against such risks as loss or unauthorized access, destruction, use, modification, or disclosure of data.
  - **Openness Principle**
    - There should be a general policy of openness about developments, practices, and policies with respect to personal data.
  - **Individual Participation Principle**
    - An individual should have the right
      a) To obtain from a data controller, or otherwise, confirmation of whether the data controller has data relating to him
      b) To have communicated to him, data relating to him
      c) To be given reasons if a request made and, if denied, be able to challenge such denial
      d) To challenge data relating to him and, if the challenge is successful to have the data erased, rectified, completed, or amended
  - **Accountability Principle**
    - A data controller should be accountable for complying with measures that give effect to the principles stated above.

- **Privacy Impact Assessment**
  - is a decision-making tool used to **identify and mitigate privacy risks at the beginning of and throughout the development life cycle of a program or system**
  - PIAs generally include the following information:
    - Description of the system
    - What PII, if any, is collected or used
    - Why it is being collected
    - From whom is the PII is collected
    - Privacy requirements (regulatory, contractual, ethical)
    - How it will be used, accessed, secured, shared

❖ **For questions and more clarity refer Data Privacy Exam Dose Link**

- **Regulation**
  - **PIPEDA**
    - Personal Information Protection and Electronic Documents Act.
    - Used In Canada
    - Penalties need to be remember
  - **GDPR** (https://www.nibusinessinfo.co.uk/content/data-protection-principles-under-gdpr)
    - General Data Protection Regulation
    - **Principles set out obligations for businesses and organizations that collect, process and store individuals' personal data. Data Breach notification: within 72 hours.**
    - **Used in EU. Right to Erasure: All users have the "Right to be forgotten"**
    - Six Privacy Principle (LPD ASI)
      1. Lawfulness, fairness, Transparency
      2. Purpose Limitation
      3. Data Minimization
      4. Accuracy
      5. Storage Limitation
      6. Integrity and Confidentiality
      7. Accountability
    - **Data breach Reporting = 72 Hours**
  - **Binding corporate rules**
    - You can make a restricted transfer if both you and the receiver have signed up to a group document called binding corporate rules (BCRs).
    - BCRs are an internal code of conduct operating within a multinational group, which applies to restricted transfers of personal data from the group's EEA entities to non-EEA group entities
    - This may be a corporate group or a group of undertakings or enterprises engaged in a joint economic activity, such as franchises or joint ventures.
    - **You must submit BCRs for approval to an EEA supervisory authority in an EEA country where one of the companies is based**
    - One or two other supervisory authorities will be involved in the review and approval of BCRs (depending on how many EEA countries you are making restricted transfers from). These will be supervisory authorities where other companies signing up to those BCRs are located.
    - **The concept of using BCRs to provide adequate safeguards for making restricted transfers was developed by the Article 29 Working Party in a series of working documents**

  - **International transfers At a glance**
    - The **GDPR primarily applies to controllers and processors located in the European Economic Area (the EEA) with some exceptions**.
    - Individuals risk losing the protection of the GDPR if their data is transferred outside of the EEA. On that basis, the GDPR restricts transfers of personal data outside the EEA, or the protection of the GDPR, unless the rights of the individuals in respect of their personal data is protected in another way, or one of a limited number of exceptions applies.
    - **A transfer of personal data outside the protection of the GDPR (which we refer to as a 'restricted transfer'), most often involves a transfer from inside the EEA to a country outside the EEA.**
    - If you wish to do so, you should answer the following questions, until you reach a provision that permits your restricted transfer:
    - **Data protection impact assessments- A Data Protection Impact Assessment (DPIA) is a process to help you identify and minimize the data protection risks of a project.**
    - **Your DPIA must: describe the nature, scope, context, and purposes of the processing; assess necessity, proportionality, and compliance measures; identify and assess risks to individuals; and identify any additional measures to mitigate those risks**.
    - To assess the level of risk, you must consider both the likelihood and the severity of any impact on individuals. The high risk could result from either a high probability of some harm, or a lower possibility of serious harm **Contracts**
    - **At a glance Whenever a controller uses a processor, it needs to have a written contract in place.**
    - The contract is important so that both parties understand their responsibilities and liabilities.

- The GDPR sets out what needs to be included in the contract.
- In the future, standard contract clauses may be provided by the European Commission or the ICO and may form part of certification schemes. However, at the moment no standard clauses have been drafted.
- **Controllers are liable for their compliance with the GDPR and must only appoint processors who can provide 'sufficient guarantees' that the requirements of the GDPR will be met and the rights of data subjects protected.**
- In the future, using a processor which adheres to an approved code of conduct or certification scheme may help controllers to satisfy this requirement – though again, no such schemes are currently available.
- **Processors must only act on the documented instructions of a controller. They will however have some direct responsibilities under the GDPR and may be subject to fines or other sanctions if they don't comply.**

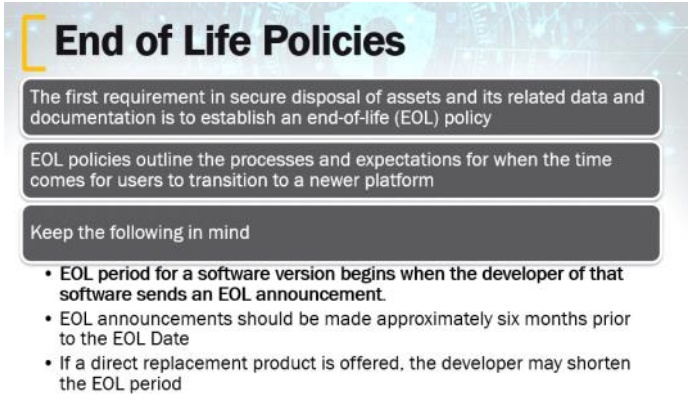
- **US Privacy Laws**

HIPPA	Health Insurance Portability and Accountability Act of 1996
GLBA	Gramm-Leach-Bliley Act of 1999
FERPA	Family Educational Rights and Privacy Act
COPPA	Children's Online Privacy Protection Act of 1998
APEC	Asia–Pacific Economic Cooperation
OECD	Organization for Economic Co-operation and Development

Data sovereignty refers to legislation that covers information that is subject to the laws of the country in which the information is located or stored

- Destroyed after its purpose is completed.
- US (Data Owner & Data Custodian)

- **Appropriate Asset Retention**
  - **End of Life Policies Process**
    a. General Availability / Sale Date (GA)
    b. End of Life / End of Sale (EOL or EOS)
    c. End of Development (EOD)
    d. End of Service Life / End of Support (EOSL)



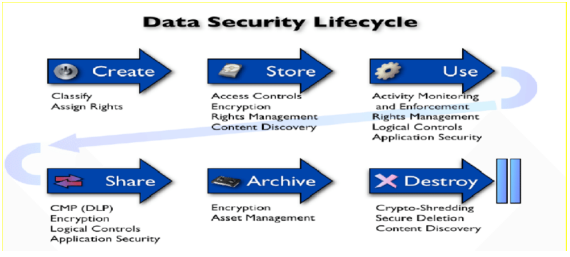
- **Retention**
  - Data retention, which is sometimes also referred to as records retention, is defined as the continued and long-term storage of valuable assets.
  - Companies are required to comply with legal and regulatory legislation in retaining assets, especially information and records.
  - **Retention**
    - Data retention, which is sometimes also referred to as records retention, is defined as the continued and long-term storage of valuable assets.
    - Companies are required to comply with legal and regulatory legislation in retaining assets, especially information and records.
    - Retention is a protocol (set of rules) within an organization that dictates types of unaltered data that must be kept and for how long.
    - Legal and regulatory requirements must be considered.
    - **A data retention policy can help to ensure that outdated data is purged, removing potential additional costs for discovery.**
    - Many organizations have aggressive retention policies to both reduce the cost of storage and limit the amount of data that is kept on hand and discoverable.
    - **A well-documented policy for the retention of data is a minimum but necessary component of regulatory compliance.**
    - Data retention policies are not designed to destroy incriminating data, and legal requirements for data retention must still be met.
    - The data retention policy should address what data to keep, where to keep it, how to store it, and for how long to keep it. The policy is not concerned with "for whom" the data is kept.

- Asset and data retention is essential for organizations to protect and preserve records as evidence of actions
- A proper data retention process will support institutional memory. In legal or forensic examinations, evidence can be preserved through data retention. In many cases, data retention is an obligation resulting from regulatory and compliance requirements.
- The most important role a security practitioner might have in asset retention is to create and maintain a policy that is informed by and adheres to regulations, meets business objectives, and is understood and followed throughout the organization

○ **Record Retention**

- Organizations may have to keep certain records for a period as specified by industry standards or in accordance with laws and regulations
- Security practitioners should ensure that accurate records are maintained by the organization regarding the location and types of records stored.
- Record retention policies are used to indicate how long an organization must maintain information and assets

- **Assets/Data Lifecycle**
  - To protect assets properly, one must understand the asset lifecycle and apply protection mechanisms throughout the phases of the asset lifecycle.
  - The lifecycle of data is depicted as having six phases: create, store, use, share, archive, and destroy. (CSUSAD)



  - Archive
    - Archiving is the process of securely storing unaltered data for later potential retrieval.
    - Backup and replication are the process of making copies of data to ensure recoverability.

- **Legal Holding**
  - A legal hold is a requirement for an organization to preserve all forms of relevant information when litigation, audit, or government investigation is reasonably anticipated.
  - The objective is to avoid evidence spoliation.
  - **A legal hold supersedes organizational retention policies.**
  - eDiscovery (also called electronic discovery) refers to any process in which electronic data is sought, located, secured, and searched with the intent of using it as evidence in a civil or criminal legal case.

- **Data Quality Standards**
  - Characteristics



- Processing Data
  - **Quality Control (QC)**
    - Introduce several controls and control standards, process the data according to these controls.
- Assessment of quality based on internal standards
  - **Quality Assurance (QA)**
    - Assessment of quality based on standards external to the process and involves reviewing of the activities and quality control processes.
    - there are two things to remember
      - **Preventing - error while processing data**

- **Correcting - error while processing data**

- Configuration Management Database (CMDB)
  - A logical entity with key integration points supports and enables processes in service delivery, service support, IT asset ma nagement, and other IT disciplines
  - Software Licensing - Original copies of licensed software must be controlled by the organization to prevent copyright infringement.
  - All software copies should be managed by a software or media librarian, conduct inventory scans of installed software.

- **Data Security Controls**
  - Data Standard
    - Describe objects, features, or items that are collected, automated or affected by activities or the functions of organizations.
    - During Implementation of data, standards consider the below
      - **International Laws---->National--->Regional--->Local Laws**

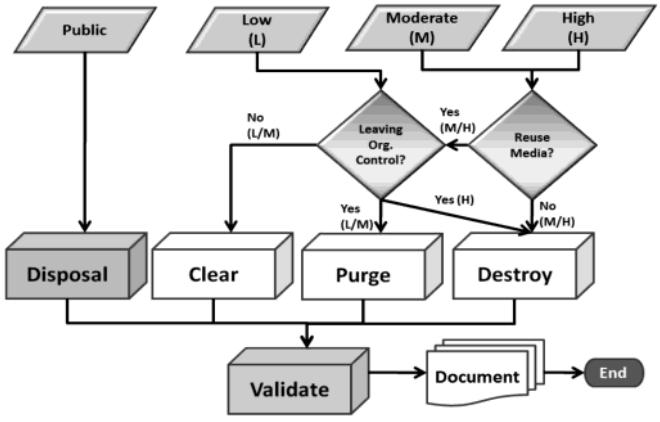
- Data Remanence **(VERY IMP TOPIC FOR EXAM)**
  - Data Remanence is defined as the residual data remaining on some sort of object after the data has been deleted or erased.
    - The problem related to data remanence is that there may some physical characteristics of that data remaining on the media even after we've tried to securely erase it.
  - Data remaining on media that use magnetic technologies, such as HDDs, become an issue if the value of the data that was store d on that media is high.
  - Secure method of addressing Data Remanence
  - **Media sanitization refers to a process that renders access to target data on the media infeasible for a given level of effort .**
  - **Type of Media Sanitization Types**
    - **Clearing**
      - **Is defined as the removal of sensitive data from storage devices, using methods that provide assurance that the data may be reconstructed using the most known data recovery techniques.**
      - It's a **least secure**
      - It is typical to use random passes of 0 and 1 combinations, not patterns, to overwrite
      - **Maybe recoverable with special lab equipment. Data just overwritten.**
      - Overwriting
        - Zeroization (S/W Overwrite)
        - One common method used to address data remanence is to overwrite the storage media with new data. We can overwrite with zeroes or ones.
        - This is sometimes called wiping. The simplest overwrite technique is to write zeroes over the existing data and depending on the sensitivity of the data, this might need to be done several times.
    - **Purging**
      - Purging sometimes referred to as Advance SANITIZING is the removal of sensitive data from media with the intent that the sensitive data cannot be reconstructed by any known technique.
      - More intense than clearing. Media can be reused in lower systems.
      - Data erasing
      - Degaussing
        - Technique uses a degausser that erases the information on the magnetic media by applying a varying magnetic field to the media to erase the information that was stored using magnetic technology.
        - The media is saturated with a magnetic field that erases all of the information.
        - AC erasure; alternating magnetic fields, DC erasure; unidirectional magnetic field or permanent magnet, can erase tapes.
      - For example, the U.S. government doesn't consider any purging method acceptable to purge top secret data. Media labeled top secret will always remain top secret until it is destroyed.
    - **Destruction**
      - The destruction method should be driven by the value of the sensitive data that is residing on the media.
      - Destruction of the media is the best method as it destroys the media and also the data that is on it.
    - **Crypto-shredding**
      - It's also called crypto erasure
      - Crypto-shredding is the practice of 'deleting' data by deliberately deleting or overwriting the encryption keys
      - Used in cloud
    - Declassification involves any process that purges media or a system in preparation for reuse in an unclassified environment.
      - Sanitization methods can be used to prepare media for declassification, but often the efforts required to securely declassify media are significantly greater than the cost of new media for a less secure environment.

  - **Clearing and Purging of writeable Electronic Storage Media should be performed using tools**
  - **Destruction techniques should be used when Clearing and Purging are not effective (e.g. single-write media or media that is permanently write**

protected).

- **While most devices support some form of Clear, not all devices have a reliable Purge mechanism. For moderate confidentiality data, the media owner may choose to accept the risk of applying Clear techniques to the media, acknowledging that some data may be able to be retrieved by someone with the time, knowledge, and skills to do so.**
- **Purge (and Clear, where applicable) may be more appropriate than Destroy when factoring in environmental concerns, the desire to reuse the media (either within the organization or by selling or donating the media), the cost of a media or media device, or difficulties in physically**

- Clearing (least secure) - Data unreadable
- Purging/Sanitizing - Data erasing / Data Removal
- Destruction (most secure) - Disk destruction



- **Baseline**
  - A baseline is a consistent reference point.
  - Baselines are minimum security needs to be implemented in the organization,
  - Baselines provide a definition of the minimum level of protection that is required to protect valuable assets
- Common security configurations, Use Group Policies to check and enforce compliance.
- On top of the baselines, we build standards, procedures, and controls.
- Catalogs of baseline safeguards could be obtained from
  - International and national standard organizations
  - Industry sector standards or recommendations
  - Some other company, preferably with similar business objectives
- Consideration
  - Which parts of the enterprise or system can be protected by the same baseline?
  - Should the same baseline be applied to the whole enterprise?
  - At what security level should the baseline aim?
  - How will the controls forming the baseline be determined?
- **Scoping and Tailoring**
  - Scoping - Which portion of the standard will be employed
    - limiting general baseline recommendations by removing those that do not apply
    - taking a broader standard and trimming out the irrelevant or otherwise unwanted parts
  - Tailoring - Customization of the standards to fit the organization
    - altering baselines recommendations to apply more specifically
  - **First Scope and then Tailor to suit the org requirement.**
  - Information asset protection standards is to balance the value of the information with the cost of protecting it.
  - Asset inventories and classification standards will help you determine the right security controls

- **Data States**
  - Three areas of data that must be considered in securing. Implement different types of security at all types of data.
    - **Data at Rest**
      - Data stored on media in any type of form. It is at rest because it is not being transmitted or processed in any way. (Persistent Storage e.g. disk, tape)
      - When data is at rest malicious users may
        - Gain unauthorized physical or logical access to a device
        - Transfer information from the device to an attacker's system
        - Perform other actions that jeopardize the confidentiality of the information on a device

- Data at Rest - Recommendations - Compliance - **FIPS and AES.**
- DAR Protection
  - **TPM - Chip integrated with Computers HD that provide a crypto processor**
    - **It provide device authentication = very important**
    - secure cryptoprocessor that provides secure storage and cryptographic services
    a) Generate, store, and limit the use of cryptographic keys.
    b) Use TPM technology for platform device authentication by using the TPM's unique RSA key, which is burned into itself.
    c) Help ensure platform integrity by taking and storing security measurements
    d) Provide secure state and integrity state
    e) TPM Offer
      - TPM is essentially a security chip that is hardwired into a system (e.g., on a motherboard).
        - At its core, a TPM is responsible for the following functions:
          - Attestation: Creates a cryptographic hash of the system's known good hardware and software state, allowing third-party verification of the system's integrity
          - Binding: Encrypts data using a cryptographic key that is uniquely associated with (or bound to) the system
          - Sealing: Ensures that ciphertext can be decrypted only if the system is attested to be in a known good state

  - SED - Self Encryption Drive - Encryption key is included but should be stored separately & update regularly.
- Removable media should be labeled, When unattended, the removable media should be stored in a secured and locked location. Document the physical location of removable media.

- Data in Use (CPU processing or in RAM)
  - Data that is being processed by applications or processes.
  - It might also be in the process of being viewed by users accessing it through various endpoints or applications
  - Digital Asset Management (DAM) & Data Leakage Prevention (DLP) - Effective when Data in Use
  - **When Data in Use encryption will not work,** The alternate solutions are Masking, Obfuscation, Anonymization, and Tokenization.
  - Data Anonymization
    - **Anonymization is the process of removing identifiers in order to prevent identification of individuals or sensitive information.**
      - Process of removing all relevant data so that it is theoretically impossible to identify the original subject or person.
      - Data inference techniques may be able to identify individuals, even if personal data is removed. This is sometimes referred to as reidentification of anonymized data

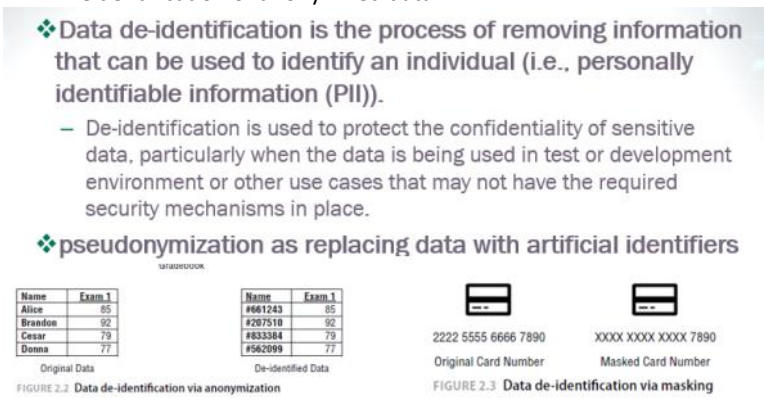
  - 

    FIGURE 2.2 Data de-identification via anonymization
    FIGURE 2.3 Data de-identification via masking

  - Pseudonymization techniques which involve replacing actual data with pseudonyms
    - Pseudonymization makes personal data processing easier, reducing the risk of exposing sensitive data to unauthorized personnel and employees.
    - Pseudonymization techniques differ from anonymization techniques. With anonymization, the data is scrubbed for any information that may serve as an identifier of a data subject. Pseudonymization does not remove all identifying information from the data but merely reduces the likability of a dataset with the original identity of an individual (e.g., via an encryption scheme).
    - Type of Pseudonymization
      - Scrambling
      - Encryption
      - Tokenization
      - Data blurring

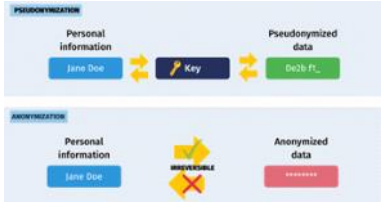
  - 



FIGURE 2.3 Data de-identification via masking

- **Obfuscation Type /Masking**
  - Masking is less secure than encryption.
  - Static masking - When data is not in use, Ex: Allowing a customer service representative limited access to account data. Data at Rest, used in a non-production environment.
  - Dynamic masking - Data at Use, Creating a test environment for a new application.

- **Data in Transit (Transmission)**
  - Data that moves, usually across networks, is said to be data in motion, or in transit.
  - Prevent the contents of the message from being revealed even if the message itself was intercepted in Transit.
  - Two Types of encryptions while data Transit
  - **Link Encryption - Performed by Service Provider**
    - Link encryption encrypts all of the data along with the communications path, done by the Service Provider.
    - **Link encryption is more secure then end to end**
    - In the case of Link encryption, a Symmetric key is used provided they are the same service provider and Diffie–Hellman
    - Each hop has to decrypt the headers, if a node is compromised then the traffic passing through that node is considered compromised as well.
    - Key Distribution and management are complex. Each hop must receive a key and when the key changes this needs to be changed at each hop.
    - Tunnel mode of VPN
  - **End to End Encryption - Performed by Consumer**
    - The data are encrypted at the start of the communications channel or before and remain encrypted until decrypted at the remote end. Although data remains encrypted when passed through a network, routing information remains visible.
    - It is possible to combine both types of encryption. Which is Performed by the end-user. End to end is easier (ex: Data/WhatsApp) Link is between the routers (Ex: MPLS network /VPN), by end of the day they both use a common algorithm.
    - Transport mode of VPN

    HTTP - Use HTTPS/TLS/SSL offered Integrity & confidentiality
    E-mail - Use SMIME/PGP - Pretty Good Privacy
    S/MIME offers C, I, Authenticity and nonrepudiation

- **Data Security in Cloud**
  - Protecting data moving to and from the cloud -- SSL/TLS/IPsec
  - Protecting Data in the cloud -- Encryption
  - Detecting of data migration to the cloud -- DAM and DLP
  - Data Dispersion
    - Data is replicated across multiple physical locations in the cloud for high availability
  - Data Fragmentation
    - Splitting the data into smaller fragments or Shards and distributing them across a large set of machines.

- **Information and Asset Handling Requirements**
  - The first step in protecting information system data is to identify and categorize the types of data is present.
  - The next step is to label, mark or otherwise classify the types of data to ensure the proper level of protection is employed.
  - Labels
    - Labels are used to identify assets so users can apply the appropriate handling standard.
    - Labeling is influenced by the intended audience
    - Labels can be digital, print, audio, or visual
      - Noted on or in a document
      - Written on or attached to media
    - There are two types of labeling - Physical (Physically attached), Logical (Logical labeling), DLP will inspect the label content based on the data label.
    - Labeling and marking are the same. Although marking and labeling are similar and may seem synonymous, labeling can be thought of as the mechanism you use to mark your data. Labeling what the classification is
    - Marking as nothing the handling instructions on the asset based on the classification (*how* the asset should be protected based on its classification).
    - The term **security labeling** refers to the association of security attributes with subjects and objects represented by internal data

structures within organizational information systems, to enable information system-based enforcement of information security policies. (NIST SP 800-53 R4)
    - The term **security marking** refers to the association of security attributes with objects in a human-readable form, to enable organizational **process-based** enforcement of information security policies. (NIST SP 800-53 R4)
- **Marking**
    - Storage media should have a physical label identifying it
    - Indicate if the media is encrypted
    - Point of contact and retention period information should be available.
    - When media is found of discovered without a label, it should be labeled at the highest level of sensitivity until the analysis reveals otherwise
    - Organizations should have policies in place regarding the marking and labeling of media based on its classification.
    - Storage media should have a physical label identifying the sensitivity of the information contained.
    - The label should indicate if the media is encrypted.
    - The label may also contain information regarding a point of contact and a retention period.
    - **When media is found or discovered without a label, it should be immediately labeled at the highest level of sensitivity until the appropriate analysis reveals otherwise**
- **Media**
    - Media storing sensitive information requires physical and logical controls
    - Media lacks the means for digital accountability when the data is not encrypted, For this reason, extensive care must be taken when handling sensitive data
    - Logical and physical controls, such as marking, handling, storing, and declassification, provide methods for the secure handling of sensitive media containing sensitive information.
- **Handling**
    - Inform custodians and users how to interact with information assets.
    - Handling standards are generally related to classification, data state, and legal or regulatory requirements
    - The first step in protecting information system data is to identify and categorize the types of data is present.
    - The next step is to label, mark or otherwise classify the types of data to ensure the proper level of protection is employed.
    - **Storing** Sensitive media should not be left tying about where a passerby could access it, whenever possible, backup media should be encrypted and stored in a secure manner.
    - **Destruction:** Media that is no longer needed or is defective should be destroyed rather than simply disposed of. Record of the destruction should be used that corresponding to any logs used for handling media.

- **Data handling procedures, keep the following in mind:**
    - Cost: There is a cost associated with acquiring and protecting data.
    - Ownership and Custodianship: Specify who is the data owner and who is the data custodian.
    - Privacy: Consider guidelines for what information is considered private, and how that information will be stored, managed, and used.
    - Liability: Does the data or loss of the data present any liability issues? Can protection be gained with banners informing users of the importance of protecting the data? Can end-user agreements be stipulated? Is the data licensed or licensable?
    - Sensitivity: If there is sensitive data, perform a risk analysis to determine appropriate processes for access.
    - Existing Law and Policy Requirements: Be aware of the laws and regulations surrounding the data you have acquired

---

CBK Notes

- A data policy that defines strategic long-term goals and provides guiding principles for data management in all aspects of a project, agency, or organization.
- A data policy that defines strategic long-term goals and provides guiding principles for data management in all aspects of a project, agency, or organization.
- Clearly defined roles and responsibilities for those associated with the data, in particular of data providers, data owners, and custodians
- Clear and documented published data that is available and useable to users, with consistent delivery procedures.
- Data owners generally have legal rights over the data, along with copyright and intellectual property rights
- Custodianship is generally best handled by a single role or entity that is most familiar with a dataset's content and associated management criteria
- Quality, as applied to data, has been defined as fitness for use or potential use
- Documentation is the key to good data quality. Without good documentation, it is difficult for users to determine the fitness for use of the data and difficult for custodians to know what and by whom data quality checks have been carried out
- Data modeling is the methodology that identifies the path to meet user requirements.
- Efforts should be made by the security practitioner to stay current on new threats so that a database and its data are not put at risk.
- Security involves the system, processes, and procedures that protect a database from unintended activity.
- Minimizing negative impact on an enterprise and the need for a sound basis in decision making are the fundamental reasons enterprises implement a risk management process for their IT systems
- Media storing sensitive information requires physical and logical controls. The security professional must continually bear in mind that media lacks the means for digital accountability when the data is not encrypted
- The need for media marking typically is strongest in organizations where sensitive IP and confidential data must be stored and shared amongst

multiple people

- **Policies and procedures describing the proper handling of sensitive media should be promulgated**
- Sensitive media should not be left lying about where a passerby could access it
- Media that is no longer needed or is defective should be destroyed rather than simply disposed
- A periodic review of retained records is necessary to reduce the volume of information stored and ensure that only relevant information is preserved
- The security professional needs to be aware of developments locally, nationally, and internationally that could potentially have an impact on the issues surrounding data protection, user privacy, and data retention
- SSDs have a unique set of challenges that require a specialized set of data destruction techniques. Unlike HDDs, overwriting is not effective for SSDs
- Due to the unique complexities of SSDs, the best data destruction method is, in fact, a combination of all these techniques – crypto-erase, sanitization, and targeted overwrite passes
- The use of cloud-based storage today also presents a data remanence challenge for the security practitioner
- Classification is concerned primarily with access, while categorization is primarily concerned with the impact
- Categorization is the process of determining the impact of the loss of confidentiality, integrity, or availability of information to an organization
- Categorization is the process of determining the impact of the loss of confidentiality, integrity, or availability of information to an organization
- Classification and categorization are used to help standardize the defense baselines for information systems and the level of suitability and trust an employee may need to access information.
- Proper data classification also helps the organization comply with pertinent laws and regulations.
- All software copies should be managed by a software or media librarian who is responsible for maintaining control over software assets, both physically and as information assets
- The security practitioner should guide the organization so that it understands the importance of training employees as soon as the record retention policy is adopted
- The security practitioner should conduct periodic audits to ensure that records are being retained and destroyed appropriately.
- Because link encryption also encrypts the routing information, it provides traffic confidentiality better than end-to-end encryption.
- Data controller determines the need and how the data will be processed.
- Data processor is a separate legal entity processing data for the controller.
  - Cloud providers are generally considered data processors, as are market research firms, payroll companies, accountants
- Data stewards establish internal and external data access requirements for data in their functional area
- Asset disposal policy should differentiate between assets being reused within the organization and those to be repurposed outside of the organization
- Data sovereignty refers to legislation that covers information that is subject to the laws of the country in which the information is located or stored
- Government and law enforcement access to information in the United States may have special considerations based on industry
- The best practices in data protection and privacy begin with establishing governance for collection limitation
  - This privacy principle, collection limitation, is addressed in every major privacy framework
- Data subjects must be able to have knowledge about or give consent for the data being collected
- The purpose of the data collection, meaning how the data will be used and why the data is needed, should be disclosed.
- Archival storage will enable an organization to follow the guidance through a hierarchal storage approach to records management
- Record retention requirements should also be complemented with de-identification and obfuscation processes
- HSM may also be used to support the archiving process, where more robust storage is available for long-term storage
- Data loss prevention (DLP) systems are aided by using digital markings, as sensitive information can be more easily identified before it leaks out of an organization.
- **The proper acquisition, inventorying, monitoring, and security management of assets in organizations around the world is a significant undertaking.**
- The choice of standards or frameworks and the individual security controls put in place to protect confidentiality, integrity, and availability of assets will also differ from one organization to the next
- The process for asset management will include multiple stakeholders within the organization, so roles and responsibilities must be clearly documented, and people should be trained adequately
- Link encryption offers a couple of advantages:
- Less human error because the process of encryption is automatic.
- Traffic analysis tools are circumvented, and attackers are thwarted because a continuous communications link with an unvarying level of traffic maintains the encryption protections.
- The following are some leading security protocols used to protect data in transit:
  - Web access: HTTPS
  - File transfer: FTPS, SFTP, SCP, WebDAV over HTTPS
  - Remote shell: SSH2 terminal
  - Remote desktop: radmin, RDP
  - Wireless connection: WPA2